RESUMEN

Módulo 6: Respuesta Inicial a Incidentes

- ✓ La respuesta inicial no es resolver el incidente. Es hacer lo correcto primero: validar, preservar, coordinar y escalar.
- ✓ Analizar responde '¿qué está pasando?' La respuesta inicial responde '¿qué hacemos ahora?'
- ✓ El SOC tiene 5 objetivos: entender el escenario, preservar evidencia, definir si escalar, evitar daño operativo y comunicar.
- ✓ Las acciones se clasifican en: seguras (no modifican el entorno), requieren autorización, o no recomendadas sin preservar primero.
- ✓ Preservar → Contener → Remediar. Saltear el orden destruye evidencia. Si hay urgencia, documentar qué se saltó y por qué.
- ✓ El SOC coordina pero no actúa solo. IR, IT, identidad, redes, apps, cloud y negocio tienen roles en la respuesta inicial.
- ✓ Comunicar bien es tan importante como analizar bien. Hechos observados, hipótesis y recomendación son tres niveles distintos.
- ✓ La secuencia operativa: confirmar → revisar → evaluar → preservar → decidir → escalar/contener → comunicar.
- ✓ Con incertidumbre: documentar limitaciones y decidir proporcional al riesgo. No inventar certeza. No esperar indefinidamente.

Responder inicialmente no significa resolver todo. Significa actuar con criterio.

⚠️ Errores comunes — Módulo 6: Respuesta Inicial a Incidentes

✘ Aislar servidores críticos sin coordinación

✔️ El SOC no decide solo en sistemas productivos. Coordinar con IT, IR y negocio antes de contener.

✘ Borrar archivos sospechosos sin preservar evidencia

✔️ Sin hash, ruta y muestra, el análisis posterior se vuelve imposible. Siempre registrar primero.

✘ Reiniciar equipos para 'solucionar rápido'

✔️ Reiniciar destruye evidencia volátil: procesos, conexiones, memoria, estado del malware.

✘ Escalar sin contexto suficiente

✔️ 'PowerShell sospechoso, revisar' no permite que nadie actúe. Incluir usuario, host, evidencia y recomendación.

✘ No escalar por miedo a equivocarse

✔️ Si hay señales fuertes de riesgo, escalar con las limitaciones documentadas. Esperar certeza perfecta puede ser peligroso.

✘ Bloquear servicios cloud compartidos sin validar

✔️ Bloquear drive.google.com puede afectar cientos de usuarios y procesos. Siempre validar impacto.

✘ No documentar acciones tomadas

✔️ Sin registro, el siguiente turno no sabe qué se hizo. El handoff se vuelve inútil.

✘ Comunicar con alarmismo o sin certeza

✔️ 'Tenemos ransomware' sin evidencia genera pánico. Usar 'compatible con posible actividad de ransomware'.



HIDDEN SECURITY

Modern SOC Operations — Módulo 6